

Clase 311 — Clasificación y ciclo de vida de los datos

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide, 9.ª ed. — Dominio 2: Asset Security 🛡️ Duración estimada: **90 min** · Nivel: **Intermedio**

🎯 Objetivo

Comprender cómo una organización identifica, valora y clasifica sus activos de información, y cómo gobierna cada dato a lo largo de su ciclo de vida (creación → uso → archivo → destrucción). Al terminar sabrás diseñar un **esquema de clasificación**, asignar los **roles de datos** (propietario, custodio, procesador) y aplicar **etiquetado y manejo** coherentes con marcos como CISSP Asset Security, NIST SP 800-60 e ISO/IEC 27001 Anexo A.8.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** clasificación (confidencialidad) de categorización (impacto FIPS 199).
2. **Definir** un esquema de niveles adaptado a una organización (comercial y gubernamental).
3. **Asignar** los roles de datos y sus responsabilidades sin solapamientos.
4. **Trazar** las siete fases del ciclo de vida del dato y los controles de cada una.
5. **Diseñar** una guía de etiquetado y manejo (labeling & handling) verificable.
6. **Relacionar** la clasificación con requisitos legales (GDPR, HIPAA, PCI DSS).

📖 Temas

#	Tema	Por qué importa
1	Valor del activo de información	Sin valoración no hay control proporcional al riesgo
2	Esquemas de clasificación	Determina el nivel de protección exigido
3	Categorización por impacto (FIPS 199 / 200)	Base del RMF federal y de la selección de controles
4	Roles de datos (owner, custodian, processor)	Define quién decide y quién ejecuta
5	Ciclo de vida del dato	Los controles cambian según la fase
6	Etiquetado y marcado	Hace operable la clasificación en el día a día
7	Datos en reposo, tránsito y uso	Cada estado exige controles distintos
8	Cumplimiento y datos regulados	PII/PHI/PCI imponen mínimos legales

📖 Definiciones y características

- **Clasificación de datos:** proceso de asignar una etiqueta de sensibilidad (p. ej. *Confidencial*) según el daño que causaría su divulgación. Característica clave: se basa en **confidencialidad** y la decide el

propietario del dato.

- **Categorización de seguridad:** en el mundo federal EE. UU., asignar niveles de impacto **bajo/moderado/alto** a confidencialidad, integridad y disponibilidad (FIPS 199). Característica: alimenta la selección de líneas base de NIST SP 800-53.
- **Data owner (propietario):** rol de negocio, normalmente directivo, responsable último de clasificar el dato y aprobar accesos. Rinde cuentas (accountable), no ejecuta.
- **Data custodian (custodio):** rol técnico (TI/operaciones) que implementa y mantiene los controles definidos por el propietario: backups, cifrado, parches.
- **Data processor:** entidad que trata datos por cuenta del controlador; término central en GDPR. Característica: actúa bajo instrucciones documentadas del controlador.
- **PII / PHI / SPI:** información personal identificable, información de salud protegida y información personal sensible. Característica: su tratamiento está regulado por ley.
- **Ciclo de vida del dato:** secuencia crear → almacenar → usar → compartir → archivar → destruir; cada fase tiene controles y riesgos propios.

Herramientas y preparación

Esta es una clase de gobierno (GRC): el "laboratorio" es de diseño documental, no de comandos. Prepara:

- Una **hoja de cálculo** (Excel, Google Sheets o LibreOffice Calc) para el inventario y la matriz.
- Plantillas de referencia: NIST SP 800-60 Vol. II (mapeo de tipos de información) e ISO 27001 A.8.
- Opcional: una herramienta de **descubrimiento/clasificación** para ver el concepto en la práctica (Microsoft Purview Information Protection, AWS Macie o el open source Apache Tika para extracción de metadatos). Úsalas solo sobre datos de prueba propios.

Laboratorio guiado — Diseñar un esquema y una política de clasificación

Trabajarás sobre una empresa ficticia, "**NovaSalud**", clínica con datos clínicos y de pago.

1. **Inventario de activos.** Crea una hoja con columnas: **Activo**, **Tipo de dato**, **Ubicación**, **Formato**, **Propietario**, **Volumen**. Registra al menos 8 activos (historias clínicas, nómina, tarjetas de pago, marketing, código fuente, etc.).
2. **Define el esquema de clasificación.** Propón 4 niveles comerciales: **Público**, **Interno**, **Confidencial**, **Restringido**. Para cada uno documenta: criterio de asignación, ejemplos, impacto de una fuga y controles mínimos.
3. **Categoriza por impacto (FIPS 199).** Para 3 activos críticos, asigna impacto bajo/moderado/alto a C-I-A y calcula la categoría como el **máximo** (high-water mark).
4. **Asigna roles.** Añade a la hoja columnas **Owner**, **Custodian**, **Processor** y complétalas. Verifica que el propietario sea de negocio y el custodio técnico.
5. **Traza el ciclo de vida.** Para la "historia clínica", describe controles en cada fase: creación (validación, minimización), almacenamiento (cifrado en reposo), uso (control de acceso, registro), compartición (cifrado en tránsito, acuerdos), archivado (retención) y destrucción (sanitización — se detalla en la clase 312).
6. **Guía de etiquetado.** Define cómo se marca cada nivel: encabezado/pie en documentos, etiqueta de metadatos en archivos, banner en sistemas, marcado físico en soportes.
7. **Regla de agregación.** Documenta que un conjunto de datos individualmente **Interno** puede volverse **Confidencial** al agregarse (p. ej. directorio completo de pacientes).

Ejercicios

1. Clasifica 10 tipos de dato reales de tu organización o de un caso conocido y justifica cada nivel.
2. Explica con un ejemplo la diferencia entre **propietario** y **custodio** de datos.
3. Aplica FIPS 199 a un sistema de reservas de hotel: asigna impacto C-I-A y su categoría.
4. Redacta la sección "Manejo" para el nivel **Restringido**: transmisión, almacenamiento, impresión y descarte.
5. Analiza un caso de **reclasificación**: ¿cuándo un dato **Confidencial** pasa a **Público**? Da criterios.
6. Diseña una matriz que cruce nivel de clasificación × estado del dato (reposo/tránsito/uso) con el control exigido en cada celda.

Reto verificable

Entrega una **Política de Clasificación de Datos** de 2–3 páginas para NovaSalud que incluya: esquema de 4 niveles con criterios, tabla de roles (owner/custodian/processor), guía de etiquetado y manejo por nivel, y el ciclo de vida con controles por fase.

Criterio de aceptación: un revisor externo, leyendo solo tu política, puede clasificar correctamente 5 activos nuevos que no estaban en el inventario y decir qué controles aplicarles, sin hacerte ninguna pregunta adicional.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Todo es Confidencial"	Sobreclasificación: encarece controles y erosiona la etiqueta. Reserva los niveles altos para daño real y alto.
El de TI decide la clasificación	Confusión de roles: clasifica el propietario de negocio ; TI es custodio. Resigna.
Niveles sin criterios objetivos	Etiquetas sin definición → inconsistencia. Documenta criterio y ejemplos por nivel.
Se clasifica el dato pero no se etiqueta	Sin marcado, la política no se aplica en la práctica. Añade guía de etiquetado obligatoria.
Ignorar la agregación	Datos benignos agregados revelan lo sensible. Añade regla de agregación al esquema.
Olvidar la fase de destrucción	Datos "muertos" siguen siendo pasivo de riesgo. Enlaza con retención y sanitización (clase 312).

Preguntas frecuentes

? ¿Cuántos niveles de clasificación debe tener una empresa? No hay número mágico, pero 3–4 suele bastar en el mundo comercial. Demasiados niveles generan confusión; muy pocos no discriminan el riesgo. El gobierno usa Unclassified/Confidential/Secret/Top Secret.

? ¿Clasificación e categorización son lo mismo? No. La clasificación se centra en confidencialidad (¿qué daño causa la divulgación?). La categorización (FIPS 199) valora impacto en C-I-A para elegir líneas base de

controles.

? ¿Quién es responsable si un dato mal clasificado se filtra? La rendición de cuentas (accountability) recae en el **propietario del dato**; la responsabilidad operativa del control fallido, en el **custodio**. Por eso deben estar definidos.

? ¿La clasificación cambia con el tiempo? Sí. Un plan estratégico puede ser **Restringido** antes de anunciarse y **Público** después. Define un proceso de reclasificación y desclasificación con aprobación del propietario.

Referencias

- (ISC)² — *CISSP Official Study Guide*, 9.^a ed., Dominio 2 Asset Security (Wiley/Sybex).
- NIST FIPS 199 — *Standards for Security Categorization of Federal Information and Information Systems*. <https://csrc.nist.gov/pubs/fips/199/final>
- NIST SP 800-60 Rev. 1 — *Guide for Mapping Types of Information and Systems to Security Categories*. <https://csrc.nist.gov/pubs/sp/800/60/v1/r1/final>
- ISO/IEC 27001:2022, Anexo A.8 Asset management.
- NIST SP 800-53 Rev. 5 — familia de controles, para líneas base derivadas de la categorización.

Siguiente clase

Clase 312 - Retención, destrucción segura de datos y DLP